E5 - RELATORIO DE PHISHING, ENGENHARIA SOCIAL E CONSCIENTIZACAO

1. **Configuracao Tecnica de Autenticacao de E-mail**

Para impedir a falsificacao de remetentes (spoofing) e proteger a comunidade contra ataques de phishing direcionados, o dominio oficial da infraestrutura (vilaaurora.org) possui implementacoes rigidas de padroes de autenticacao de e-mail ao nivel de DNS:

- SPF (Sender Policy Framework): Configurado para autorizar exclusivamente os servidores de correio oficiais da administracao comunitaria a disparar mensagens em nome do dominio, rejeitando envios de relays nao autorizados (v=spf1 include:mail.vilaaurora.org -all).
- DKIM (DomainKeys Identified Mail): Aplicacao de uma assinatura digital criptografica nos cabecalhos de todas as mensagens enviadas pelos servicos centrais, garantindo que o conteudo nao foi alterado em transito.
- DMARC (Domain-based Message Authentication, Reporting, and Conformance): Configurado em modo estrito (p=reject), ordenando aos servidores de e-mail de destino que rejeitem imediatamente qualquer mensagem que falhe nas validacoes SPF ou DKIM, gerando relatorios automaticos de incidentes para o SOC.

2. Campanha de Simulacao Etica de Phishing

Com o objetivo de mensurar o indice de suscetibilidade a fraudes e preparar os voluntarios e operadores da comunidade, foi estruturada uma campanha de simulacao etica controlada, com consentimento previo da administracao.

2.1. O Cenario de Pretexting Utilizado

- Assunto do E-mail: [URGENTE] Manutencao Emergencial e Recadastramento de Senhas — Portal da UBS Vila Aurora
- Pretexto: O e-mail simulava uma comunicacao oficial da direcao da UBS alertando sobre uma suposta falha de seguranca nos cadastros de distribuicao de insumos e camara fria, exigindo que os voluntarios clicassem num link externo para revalidar as suas credenciais de acesso ao painel.
- O Link Simulado: Apontava para uma pagina de captura controlada (https://auth-vilaaurora-secure.internal/login), que registava o clique e a tentativa de submissao de credenciais (sem armazenar senhas reais, respeitando a privacidade e a etica).

3. Metricas e Analise de Resultados da Simulacao

A campanha foi aplicada a um grupo piloto de 50 voluntarios operacionais da comunidade. Os indicadores obtidos foram os seguintes:

- E-mails Entregues: 50 (100%) - Entrega bem-sucedida pelo servidor SMTP simulado.
- Taxa de Abertura: 38 (76%) - Elevada curiosidade devido ao carater de urgencia do assunto.
- Cliques no Link Malicioso: 14 (28%) - Alerta critico para o risco de engenharia social.
- Credenciais Submetidas: 4 (8%) - Usuarios que cairam no golpe e inseriram dados na pagina falsa.
- Conclusao da Analise: Embora a grande maioria tenha ignorado o link, os 8% que submeteram credenciais evidenciam a necessidade continua de capacitacao e a importancia de adotar duplo fator de autenticacao (MFA) em todos os acessos criticos da comunidade.

4.Mitigacao de Ameacas Avancadas (Voz Clonada e IA)

Com a evolucao das tecnicas de engenharia social assistidas por Inteligencia Artificial, o projeto mapeou cenarios de risco envolvendo deepfakes de audio (voz clonada).

- O Cenario de Risco: Um atacante utiliza amostras de voz extraidas de videos publicos de lideres comunitarios para gerar um audio falso via IA, solicitando por aplicativos de mensagens a liberacao imediata de acessos administrativos ou transferencia de recursos.
- Medida de Mitigacao Obrigatoria (Verificacao Fora de Banda): Fica estipulado por politica de seguranca que nenhuma ordem critica, alteracao de parametros em nos de borda ou liberacao de infraestrutura pode ser autorizada apenas com base em comandos de voz ou mensagens de texto urgentes. E obrigatorio o uso de um canal de confirmacao secundario (fora de banda), como uma palavra-passe verbal pre-acordada ou validacao cruzada por video no tunel seguro WireGuard.

5. **Plano de Conscientizacao Adaptado a Voluntarios**

Com base nos resultados da simulacao, o programa de educacao em ciberseguranca da Vila Aurora adotou as seguintes diretrizes praticas:

- Treinamentos Praticos Trimestrais: Simulacoes periodicas semestrais para manter o nivel de alerta elevado.
- Regra de Ouro da Desconfianca: Nunca clicar em links diretos de e-mails institucionais urgentes; em vez disso, aceder ao portal digitando o endereco oficial no navegador.
- Canal de Denuncia Rapida: Criacao de um comando simples no chat comunitario para reportar e-mails suspeitos diretamente a equipa de seguranca (SOC).